המסלול האקדמי המכללה למינהל
מדעי המחשב

ת.ז הסטודנט:_____
מס' חדר:_____ מס' נבחן:_____

בחינה בקורס: מבוא לאבטחת סייבר
קוד קורס: 689156
תאריך הבחינה: 21/07/2025 שעת הבחינה: 15:00
שנה"ל: תשפ"ה סמסטר: ב' מועד: א'
מרצה: ד"ר מנחם ליבוביץ
משך הבחינה: 01:20 שעות

- מספר השאלות בשאלון: 10
- יש להשיב על כל השאלות
- משקל כל שאלה: 10 נקודות
- הבחינה ללא חומר עזר
- שימוש במחשבון כיס: כן
- מחברת טיוטה: לא
- בכל שאלה רק תשובה אחת נכונה. יש לסמן את התשובה הנכונה ביותר בדף הקידוד. **רק דף הקידוד ייבדק!**
- את התשובות יש לסמן **בעט שחור או כחול כהה בלבד, באופן ברור ומודגש. יש להקפיד על כתב יד קריא וברור**
- אין לסמן על דף הקידוד ו/או שאלון הבחינה במַדְגֵּשׁ (מַרְקֶר) זוהר
- **חל איסור לתלוש דפים משאלון הבחינה!**
- יש להחזיר את שאלון הבחינה, כולל נספחים (אם קיימים)
- בבחינה זו מתקיים נוהל הוצאת פתקים בשעות: 15:20, 15:50. לזכאי תוספת זמן גם בשעה 16:20
  נא **לא לשאול** את השאלות הבאות בעזרת פתקים, כי לא יינתן עליהם מענה:
  - יש טעות בבחינה/בשאלה/בסעיף...
  - יש יותר מתשובה אחת נכונה או אף אחת מהתשובות לא נכונה.
  - לא למדנו על...
  - מה התרגום של [משהו] בעברית/באנגלית...
  - מה המשמעות של ראשי התיבות...
  - כל שאלה שעיקרה לגרום לגילוי התשובה

חשוב מאוד:
- בדף הקידוד יש לרשום ולקדד את מספר המבחן המופיע בראש הדף בצד ימין (מספר בן 3 ספרות)
- יש לרשום את מספר תעודת הזהות במקום המיועד בכתב יד ברור (כולל ספרת הביקורת)

בהצלחה!

<u>שאלה מספר 1:</u>

להלן מספר שיטות לשמירת סיסמאות ב DB, כאשר כל שיטה מתארת את מבנה הטבלה (המידע שישמר בכל עמודה מופרד בפסיקים, והסימן || מסמל שירשור).

Hash הינה פונקʻ hash בטוחה קריפטוגרפית.

Salt הינה מחרוזת בגודל 256 ביט הנבחרת באקראי.

איזה מבין השיטות הבאות אינה פרקטית?

כלומר, האפליקציה שמנסה לאמת את המשתמשים בעזרת הטבלה הזאת לא תוכל לעשות זאת בזמן סביר אם הטבלה תיושם לפי השיטה הספציפית?

א. Username, hash(salt), hash(password || salt)

ב. Username, salt, hash(password || salt || username)

ג. Username, salt, hash(hash(password || salt))

ד. Username, salt, hash(password || salt)

<u>שאלה מספר 2:</u>

אליס רוצה להשתמש ב textbook RSA. לשם כך, היא מריצה את אלגוריתם ה Gen. אליס התחילה את הרצת ה Gen ולכן בחרה שני מספרים ראשוניים: p=3, q=17, ובעזרתם חישבה: n=51.

על בסיס נתונים אלו, מהי התוצאה של ϕ(n)?

כאשר הפונקציה ϕ (האות היוונית phi) היא כפי שלמדנו בכיתה עבור אלגוריתם ה Gen.

א. 32

ב. 50

ג. 1

ד. 11

<u>שאלה מספר 3:</u>

בהקשר של חתימה דיגיטלית לפי textbook RSA (כלומר ללא hash), אם ידוע שה private key הוא:

n = 33

d = 7

מהי החתימה הדיגיטלית על ההודעה m כאשר m = 5?

א. 14

ב. 26

ג. 5

ד. 61

<u>שאלה מספר 4:</u>

איזה מבין הטענות הבאות נכונה?

א. עץ מרקל מאפשר לאמת אם טרנזקציה כלולה בבלוק מבלי להחזיק את כל הטרנזקציות של הבלוק.

ב. עץ מרקל משמש לחישוב כתובת הארנק של משתמשי ביטקוין.

ג. עץ מרקל מאפשר לבצע הצפנה על כל טרנזקציה באופן נפרד.

ד. עץ מרקל משמש להצפנת הכתובות של השולחים והמקבלים בכל טרנזקציה.

<u>שאלה מספר 5:</u>

איזה מבין הטענות הבאות <u>אינה</u> נכונה בהקשר של TLS?

א. ב ClientHello השרת מעביר ללקוח את ה cipher suite שהוא רוצה שהשרת והלקוח ישתמשו בו.

ב. ב-TLS handshake השרת שולח ללקוח את תעודת השרת, אשר מכילה את מפתח ההצפנה הציבורי של השרת.

ג. השרת מעביר ללקוח את התעודה של השרת, והלקוח צריך לוודא את התקינות של התעודה, בין השאר, לוודא שה subject שכתוב בתעודה (שעבורו הונפקה התעודה) הוא אכן השרת שהלקוח רוצה להקים איתו חיבור TLS.

ד. השרת מעביר ללקוח את התעודה של השרת, והלקוח צריך לוודא את התקינות של התעודה, בין השאר, לוודא שתוקף התעודה לא פג.

<u>שאלה מספר 6:</u>

מה תפקידו של מנגנון OCSP stapling?

א. לאפשר לשרת אינטרנט לשלוח ללקוח את הסטטוס המעודכן של התעודה של השרת (אם בוטלה או לא), בלי שהלקוח יצטרך לפנות בעצמו לשרת ה OCSP.

ב. לאחסן רשימה של כל התעודות שה CA ביטל.

ג. לייתר את הצורך לבדוק את ה chain of trust.

ד. מדובר במנגנון challenge הנועד לוודא ששרת אינטרנט שפנה ל CA בטענה לבעלים של דומיין מסויים הוא אכן הבעלים של הדומיין הזה.

<u>שאלה מספר 7:</u>

השם המלא של אליס הוא אליס אליסוביץ׳. לאחרונה, אליס נרשמה לאתר אינטרנט מסוים בשמה המלא (כפי שהופיע במשפט הקודם), אך שמה לב לתופעה מוזרה. במקומות מסוימים, האתר מציג את שמה נכון:

אליס אליסוביץ׳

אך במקומות מסוימים אחרים שקשורים לאתר הזה, שמה מוצג בצורה שונה:

אליס אליסוביץ'

מהי הסיבה לכך?

א. שימוש במנגנון קידוד (encoding) על ידי האתר על מנת למנוע התקפות injection.

ב. השרת הגדיר Content Security Policy עבור מנגנון OCSP.

ג. שימוש במנגנון ה preload ב HSTS בלי רישום באתר https://hstspreload.org

ד. תופעת לוואי של מנגנון ה anti CSRF token.

<u>שאלה מספר 8:</u>

תוקף הצליח לגנוב את המפתח הפרטי של שרת אינטרנט מסוים. לקוחות מתקשרים מול שרת האינטרנט הזה בעזרת חיבורי TLS מבוססי RSA. שרת האינטרנט לא יודע שהמפתח הפרטי נגנב והתעודה הנוכחית שהונפקה עבורו היא התעודה היחידה שאי פעם היה לו. איזה מבין הטענות הבאות <u>אינה</u> נכונה?

א. התוקף יכול לחתום על ה CRL של ה CA שהנפיק את התעודה של שרת האינטרנט, ולקבוע איזה תעודות יכללו ב CRL הזה.

ב. אם לתוקף יש יכולת Man in the Middle כאשר לקוח מקים חיבור TLS מול שרת האינטרנט הנ״ל, התוקף יכול כעת להשלים חיבור מול הלקוח תוך התחזות אל שרת האינטרנט והלקוח יחשוב שהוא הקים חיבור TLS עם שרת האינטרנט האמיתי כשבפועל החיבור הוקם מול התוקף.

ג. אם לתוקף יש עותק של תעבורת https ישנה של השרת אינטרנט הנ״ל מול לקוחות, התוקף יכול כעת לפענח את התעבורה הזו ולראות את ה plaintext שנשלח בה.

ד. התוקף יכול לחתום על מידע כלשהו בשם שרת האינטרנט, כך שהמידע יראה ככזה שבאמת נחתם על ידי שרת האינטרנט.

<u>שאלה מספר 9:</u>

אתר מסויים מאפשר למנהלים לשנות את הסיסמה של כל משתמש דרך בקשת GET לכתובת:
http://www.foo.com/change-password?user=alice&password=1234
כלומר, אם מנהל ייגש לכתובת הזו, הסיסמא של אליס תשתנה להיות 1234 (ורק הסיסמא תשתנה), והתשובה של השרת היא 204 (סטטוס 204 של http אומר שהפעולה בוצעה בהצלחה ואין שום תוכן טקסטואלי או html וכו׳ נוסף להחזיר - ולכן גוף התשובה ריק). זה כמובן יתרחש רק אם המשתמש שניגש לכתובת הוא אכן מנהל של המערכת (נבדק על ידי cookies). נתון כי השרת לא שומר את הסיסמאות באופן גלוי, אלא משתמש ב hash ו salt כפי שנלמד.
המימוש הזה של האתר הזה מכיל חולשה. החולשה הזאת היא חולשה מסוג?

א. Cross Site Request Forgery.
ב. Cross Site Scripting.
ג. הלוגריתם הדיסקרטי.
ד. X-Frame-options.

<u>שאלה מספר 10:</u>

מה מהבאים מתאר בצורה הנכונה ביותר את ההבדל המרכזי בין הצפנה לחתימה דיגיטלית?

א. הצפנה נועדה לשמור על סודיות המידע, בעוד שחתימה דיגיטלית נועדה לאמת את מקור ושלמות המידע.
ב. הצפנה משתמשת תמיד במפתחות סימטריים, ואילו חתימה דיגיטלית תמיד משתמשת במפתחות א-סימטריים.
ג. הצפנה מונעת זיופים של המסר, בעוד שחתימה דיגיטלית מונעת גישה לא מורשית למידע.
ד. חתימה דיגיטלית היא תהליך הממיר טקסט קריא לטקסט מוצפן, בעוד שהצפנה מאמתת זהות שולח ההודעה.

--- סוף המבחן ---